

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

1	Background.....	1
2	Objective.....	2
3	Scope.....	2
4	Tasks.....	3
4.1	Task One: Kickoff Meeting.....	3
4.2	Task Two: Vulnerability and SBOM Data Ingestion and Harmonization	3
4.3	Task Three: SBOM and Vulnerability Data Comparisons.....	4
4.4	Task Four: Report Generation.....	4
4.5	Task Five: Maintenance, documentation and support of Completed System.....	4
5	Deliverables	5
5.1	Format Of Deliverables.....	5
5.2	Deliverables Submission Procedure	5
5.3	Summary Of Deliverables and Expectations	5
6	Contract Type.....	8
7	Period Of Performance	8
8	Place of Performance	8
9	Government Furnished Property.....	9
10	508 Standard Requirements	9
11	Security Requirements.....	11
12	Government Contacts.....	11
13	Holidays and Government Closures.....	12
14	Security and Privacy Considerations.....	12
15	Proposal instructions.....	25
16	Contract clauses.....	25
16.1	FAR 52.217-8 Option to Extend Services (Nov 1999)	25
16.2	HHSAR 352.239-74 Electronic Information and Technology Accessibility (Dec 2015)	26
16.3	52.204-27 Prohibition on a ByteDance Covered Application.....	27

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

1 BACKGROUND

The Food and Drug Administration (FDA) is responsible for protecting the public health by assuring the safety, efficacy, and security of human and veterinary drugs, biological products, medical devices, our nation’s food supply, cosmetics, and products that emit radiation. The FDA is also responsible for advancing the public health by helping to speed innovations that make medicines and foods more effective, safer, and more affordable, and helping the public get the accurate, science-based information they need to use medicines and foods to improve their health.

The mission of the Center for Devices and Radiological Health (CDRH) is to protect and promote the public health. CDRH assure that patients and providers have timely and continued access to safe, effective, and high-quality medical devices and safe radiation-emitting products. We provide consumers, patients, their caregivers, and providers with understandable and accessible science-based information about the products we oversee. We facilitate medical device innovation by advancing regulatory science, providing industry with predictable, consistent, transparent, and efficient regulatory pathways, and assuring consumer confidence in devices marketed in the U.S.

Section 3305 of the Food and Drug Omnibus Reform Act of 2022 (“FDORA”), enacted on December 29, 2022, added section 524B “Ensuring Cybersecurity of Medical Devices” to the Federal Food, Drug, and Cosmetic Act (FD&C Act). Under section 524B(a) of the FD&C Act, a person who submits a 510(k), PMA, PDP, De Novo, or HDE for a device that meets the definition of a cyber device, as defined under section 524B(c) of the FD&C Act, is required to submit information to ensure that cyber devices meet the cybersecurity requirements under section 524B(b) of the FD&C Act, and to submit an associated Software Bill of Materials (SBOM) under section 524B(c) of the FD&C Act. For devices that are not cyber devices that nonetheless may be exposed to cyber risk, FDA recommends that SBOMs be included as part of their premarket submissions to help demonstrate a reasonable assurance of safety and effectiveness. An SBOM is a nested inventory that makes up a full listing of all of the software components (components, packages and libraries) which are part of a medical device (when applicable).

SBOMs are typically provided in a machine-readable format, and will be part of premarket submissions (510(k), premarket approval application (PMA), Product Development Protocol (PDP), De Novo, and Humanitarian Device Exemption (HDE)) for review. It will be imperative for the reviewers to have a way to easily determine if the software components associated with the device present risks that could impact the device’s safety, effectiveness, or cybersecurity, including whether the components have any known vulnerabilities.

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

Known vulnerabilities, risks, and exploitations are different than more typical anomalies or defects in devices in that they are largely unseen, and they can “appear” at any point in time based on the technology that is being used, including technology that may be added as the device is modified or maintained. The product can work perfectly throughout clinical trials and thereafter, but then tremendous adverse effects can be introduced with the exploitation of a single vulnerability all at once. This could potentially impact all users of the device at once and cause multitudes of adverse events in a very short period of time.

2 OBJECTIVE

The Medical Device Cybersecurity Team (Cybersecurity Team) within the Food and Drug Administration’s (FDA) Center for Devices and Radiological Health (CDRH) is seeking a contractor to develop (and/or provide) and maintain a process which supports data analysis and reporting, and provide detailed cybersecurity vulnerability, risk, and exploitation information to inform reviewers and the Cybersecurity team of potential issues within devices that contain or otherwise leverage software, hardware, or firmware.

3 SCOPE

This project augment and maintain a process and reporting product within the FDA CDRH system that is used by reviewers of devices that contain or leverage software, as well as other staff members. It will integrate and work with externally acquired data assets and provide informative and easy to understand reports that detail any and all concerning factors with individual software components and packages underlying the medical device.

This system is provisioned to ingest data from outside sources as well as the SBOM itself, load said data to a common, yet protected, datastore, and create comparisons between the two. In addition to this, the system also generates reports for reviewers and staff that are clear, yet comprehensive, to help facilitate the review process as well as post-market surveillance. These reports will need to be maintained, augmented and potentially added to.

Data on known vulnerabilities, risks, and exploitations are available through multiple sources, and are updated on a timely basis (typically daily) with the latest issues and concerns that have been identified. These data are integrated into the solution, allowing for the ability to consider risks across the total product lifecycle, and will need to be maintained and augmented as needed.

The work required can be broken down into the following components:

- Vulnerability data ingestion and harmonization
- SBOM data ingestion
- SBOM and vulnerability data comparisons

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

- Report generation
- Operations and Maintenance of the System;
 - Troubleshoot issues reports;
 - Remediate bugs;
 - Routine updates and minor enhancements.

4 TASKS

In this project, the contractor shall fulfill the following tasks:

4.1 TASK ONE: KICKOFF MEETING

Within five (5) business days after the effective date of the Order, the Contractor shall participate in a Kick-Off Meeting with the Technical POC, the COR, the CO, and other CDRH Staff. The Contractor shall provide meeting materials and agenda two (2) days prior to the Kick-off meeting.

The Contractor shall prepare summary meeting minutes, detailing the discussion held, and provide a copy of the minutes to the COR and the Technical POC within five (5) business days after the meeting.

4.2 TASK TWO: VULNERABILITY AND SBOM DATA INGESTION AND HARMONIZATION

The contractor shall:

- a. Continue to identify and gather all system specifications, including infrastructure for external data ingestion as data change, are augmented and/or enhanced;
- b. Maintain a highly secure datastore (database, data lake-house) structure which houses all data that are ingested;
- c. Maintain, develop and enhance the process which ingests multiple external data files into the datastore in a standardized manner that also integrates and harmonizes these data assets into one common structure;
- d. Modify, augment and enhance a fuzzy matching algorithm to identify commonalities within words for more complete and accurate matching of software components and packages;
- e. Continue to support SBOM parsing, loading and ingestion, as well as all associated interrogation protocols from file to datastore;
- f. Ensure appropriate, efficient and effective operation and maintenance of all data pipelines and integrations.

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

4.3 TASK THREE: SBOM AND VULNERABILITY DATA COMPARISONS

The contractor shall:

- a. Continue to identify and gather all system specifications to match SBOM entries to vulnerability data;
- b. Use matching criteria which includes capture of non-specific matching (as suggested in 4.2d);
- c. Modify, augment and enhance a comparison procedure to evaluate information in vulnerability database (when applicable) and return information specified (if applicable);
- d. Maintain and enhance a datastore structure to house all results which are produced, including linkage to device, manufacturer, and reviewer;
- e. Ensure, maintain and enhance the parsing , standardization and loading of results from comparisons, including all linkage information, to said datastore;
- f. Ensure appropriate, efficient and effective operation and maintenance of all data comparisons and linkages.

4.4 TASK FOUR: REPORT GENERATION

The contractor shall:

- a. Continue to identify and gather all system and business specifications for new and existing SBOM resultant reports;
- b. Create, modify, troubleshoot and enhance reports and graphical dashboards as needed/requested.
- c. Create, modify and enhance an on-demand ability to generate multiple reports using captured underlying data, including, but not limited to:
 - a. Comparison of any software component or package to new vulnerabilities from external sources loaded during some specific time-period;
 - b. Identification of any device that has a specific software component or package;
 - c. Identification of any device that has a specific vulnerability;
- d. Ensure appropriate, efficient and effective operation and maintenance of all reports and dashboards.

4.5 TASK FIVE: MAINTENANCE, DOCUMENTATION AND SUPPORT OF COMPLETED SYSTEM

The contractor shall maintain the completed system which incorporates the functions of all other tasks listed. A process and system should be set up to support end-users for the SBOM ingestion and reporting application system. The contractor shall respond and resolve technical requests from CDRH users in an agreed-upon timeframe. The contractor shall respond to all relevant requests from FDA/CDRH regarding the IT system as discussed with government project team.

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

The contractor should also create, maintain, and provide comprehensive documentation of technical specifications as well as operational processes for the system writ large.

5 DELIVERABLES

5.1 FORMAT OF DELIVERABLES

Where applicable, deliverables (both in draft and final versions) shall be provided in hard and soft copy using MS Office products as specified below. Weekly, interim, informal, and working-copy products may be provided by e-mail to the COR. Final soft copies of deliverables shall be developed using the current FDA version of Microsoft Office products and/or other standard application software. Final hard copies of deliverables shall be typewritten on 8-1/2"x11" white paper. The Contractor shall not use spiral binding or other binding that interferes with photocopying.

5.2 DELIVERABLES SUBMISSION PROCEDURE

The Contractor shall submit all deliverables to the COR, unless otherwise stated. The COR will be responsible for the review of all draft and final deliverables to ensure accuracy, functionality, completeness, professional quality, and overall compliance with the guideline's requirements of the task. The Contractor shall ensure the accuracy and completeness of all deliverables in accordance with referenced policy, regulations, laws, and directives. Reports and presentations shall be concise and clearly written; errors, misleading or unclear statements, incomplete or irrelevant information, and/or excessive rhetoric, repetition, and "padding," or excessive length if a page limit is imposed, shall be considered deficiencies and will be subject to correction by the Contractor at no additional cost to the government. Unless specified otherwise, the government shall have ten (10) working days to complete the review and approve the deliverables. If deficiencies are found or areas require modification, the Contractor will be notified and shall have five (5) calendar days to correct the deficiencies. Upon re-submission by the Contractor, the government will reapply the same acceptance criteria. If the deliverable does not meet the acceptance criteria a second time, the government may consider the Contractor as having deficient performance with respect to the subject task.

5.3 SUMMARY OF DELIVERABLES AND EXPECTATIONS

FDA will approve each of the following deliverables and interim deliverables. These deliverables represent a minimum set of required deliverables. Additional deliverables can be proposed within the application.

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

Table 1: Deliverables

Task	Deliverables/Expectations	Quantity/Frequency	Due Date
4.1	Kickoff Meeting Minutes	One / Once	Five (5) business days after Kickoff Meeting
4.2, 4.3, 4.4	Updated and new business and technical specifications for each requirement	TBD	TBD
4.2	Updated and new business and technical mapping specifications for all data ingestion protocols from receipt of data through load to datastore	TBD	TBD
4.2	Updated and new Architecture Diagrams and Specifications as required	TBD	TBD
4.2	Modified and Enhanced Fuzzy Matching Protocol Specifications	TBD	TBD
4.4	Updated and new Report Specifications	TBD	TBD
4.5	Maintenance and Enhancements of Final System	TBD	TBD
4.1	Project Plan for all Work Products as needed	TBD	TBD
4.2	Operations and Maintenance process documentation		
	Final technical and business requirements specification		

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

Table 2: Associated Interim Deliverables

Deliverable	Associated Interim Deliverables
Updated and new Business and technical specifications for each requirement	• Maintain current and draft new business and technical specifications for each requirement; • Updated drafts based on FDA feedback; • Finalized business and technical specifications for each requirement.
Updated and new Business and technical mapping specifications for all data ingestion protocols from receipt of data through load to datastore	• Maintain current and draft new business and technical mapping specifications for each vulnerability dataset and SBOM format, including any and all transformations, standardizations, and element to datastore field; • Updated drafts based on FDA feedback; • Finalized mapping specifications as specified.
Updated and new Architecture Diagrams and Specifications as required	• Update and maintain architecture and infrastructure diagrams and specifications for entirety of system development, including: ○ Data model diagrams; ○ Tools and technologies used; ○ General User Interface (GUI) designs; ○ Workflow, Dataflow, and other salient infrastructure details.
Modified and enhanced Fuzzy Matching Protocol Specifications	• Update, modify, enhance and maintain specification to overcome challenge of unspecific words to match software component or package from SBOM to vulnerabilities database; • Updated specification; • Finalized specification for matching algorithm.
Updated and new Report Specifications	• Draft, update, modify and enhance specifications and prototype reports as described; • Updated specifications and prototype reports; • Finalized specifications and prototype for reports.
Maintained and enhanced Final System	• Maintain and enhance fully functioning system which meets the goals and criteria specified in the agreed upon and finalized specifications and diagrams;

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

	• Must be able to execute upon all of the specified needs of the above and generate agreed upon finalized reports as detailed.
Updated and new business and technical specifications for each requirement	• Draft, update, modify and maintain business and technical specifications for each requirement; • Updated drafts based on FDA feedback; • Final business and technical specifications for each requirement.

6 CONTRACT TYPE

This requirement is expected to be Firm Fixed Price contract.

7 PERIOD OF PERFORMANCE

The period of performance for this order is 5 month base period and 2 twelve month option periods. The anticipated dates of performance are:

Base Period: 09/01/2025 – 02/24/2026

Option Period: 02/24/2026 – 02/23/2027

Option Period: 02/24/2027 – 02/23/2028

8 PLACE OF PERFORMANCE

Services shall be provided both on and off-premises.

Due to the increased remote work flexibilities throughout the COVID-19 Pandemic, it is expected most work will be performed remotely. The majority of the work to be performed will occur off-site at the contractor's facilities within the Washington DC area. The contractor shall work remotely using FDA furnished property on the FDA network.

However, pending the ongoing Return 2 Facilities program, on-site work may be required to perform key interactions with FDA personnel.

Space will be provided at FDA's White Oak Headquarters:

White Oak Campus
Building 66
10903 New Hampshire Avenue,
Silver Spring, Maryland 20993.

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

9 GOVERNMENT FURNISHED PROPERTY

Government furnished property (materials, equipment, and/or information) is to be provided in conjunction with required performance under this contract as determined by mutual agreement between FDA and the Contractor.

When the Government provides equipment, then the Contractor shall maintain a detailed inventory accounting system for Government Furnished Property (GFP) following contract award. The inventory accounting system must specify, at a minimum:

- Product description (make, model)
- Government tag number
- Date of receipt
- Name of receipt
- Location of receipt
- Current location
- Contract/order number under which the equipment is being used.

The Contractor shall attach an update inventory report to each MPR unless otherwise specified by the COR. In either case, the Contractor's inventory listing must be available for Government review within one (1) business day of COR request. The Contractor shall remain responsible and accountable for all GFP for the duration of the contract and ensure the return of the property upon completion of all work required under this contract.

10 508 STANDARD REQUIREMENTS

Section 508 of the Rehabilitation Act of 1973 (29 U.S.C. 794d) requires Federal agencies to purchase information and communication technologies (ICT) that meet specific accessibility standards. This law helps to ensure that federal employees with disabilities have access to, and use of, the information and data they need to do their jobs. Furthermore, this law ensures that members of the public with disabilities have the ability to access government information and services.

There are three regulations addressing the requirements detailed in Section 508. The Section 508 technical and functional standards are codified at 36 CFR Part 1194 and may be accessed through the Access Board's Web site at <http://www.access-board.gov>. The second regulation issued to implement Section 508 is the Federal Acquisition Regulation (FAR). FAR Part 39.2 requires that agency acquisitions of information and communication technology (ICT) comply with the Access Board's standards. The entire FAR is found at Chapter 1 of the Code of Federal Register (CFR) Title 48, located at <http://www.acquisition.gov>. The FAR rule implementing Section 508 can be found at <http://www.section508.gov>. The third applicable regulation is the HHS Acquisition Regulation (HHSAR).

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

Regardless of format, all Web content or communications materials produced for publication on or delivery via HHS Web sites - including text, audio or video - must conform to applicable Section 508 standards to allow federal employees and members of the public with disabilities to access information that is comparable to information provided to persons without disabilities. All contractors (including subcontractors) or consultants responsible for preparing or posting content intended for use on an HHS-funded or HHS-managed Web site must comply with applicable Section 508 accessibility standards, and where applicable, those set forth in the referenced policy or standards documents below. Remediation of any materials that do not comply with the applicable provisions of 36 CFR Part 1194 as set forth in the SOW, shall be the responsibility of the contractor or consultant retained to produce the Web-suitable content or communications material.

Unless an agency exception to this requirement exists, the Contractor must conform to applicable Section 508 standards and must apply best practices associated with Section 508 compliance during the application design, development, and testing phases. The Contractor shall utilize FDA approved tools to verify the compliance with the Section 508 standards and ensure the delivery of the fully compliant products.

The following Section 508 standards apply to this Statement of Work (SOW):

- Must meet WCAG 2.0 A and AA
- E101.2 Equivalent Facilitation (Appendix A, Application and Scoping Requirements)
- E203 Access to Functionality (Appendix A, Application and Scoping Requirements)
- E204 Functional Performance Criteria (Appendix A, Application and Scoping Requirements)
- E205 Electronic Content (Appendix A, Application and Scoping Requirements)
- E208 Support Documentation and Services (Appendix A, Application and Scoping Requirements)
- Chapter 6 Support Documentation and Services (Appendix C, Functional Performance Criteria and Technical Requirements)
- 302 Functional Performance Criteria (Appendix C, Functional Performance Criteria and Technical Requirements)
- Electronic content must be accessible to HHS acceptance criteria. Checklist for various formats are available at <https://www.hhs.gov/web/section-508/making-files-accessible/index.html>, or from the Section 508 Coordinator listed at <https://www.hhs.gov/web/section-508/additional-resources/section-508-contacts/index.html>. Materials that are final items for delivery should be accompanied by the appropriate checklist, except upon approval of the Contracting Officer or Representative.

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

11 SECURITY REQUIREMENTS

The Contractor shall be responsible for determining that the individuals provided to perform under this order will not have an adverse effect on the efficiency, effectiveness, and integrity of the FDA, and will uphold the scope of work.

The Contractor shall be expected to have all necessary credential(s) processed prior to beginning work. All Contractor personnel must have an FDA security clearance before providing services.

All necessary administrative paperwork to hire non-FDA employees must have sufficient time to be processed in the FDA systems. The process normally takes four (4) weeks, and the Contractor shall allocate sufficient time for the new hire to be processed in the FDA system prior to the commencement of work.

The position risk level for this order is Public Trust Position – Level 5.

Furthermore, the Contractor assigned to this order shall provide verification of completion of all mandatory FDA trainings, including Annual Security Awareness Training, if assigned an FDA laptop that allows for FDA network access.

CDRH Security and Badging POC:

Name:

U.S. Food and Drug Administration

White Oak Campus, Building 66

10903 New Hampshire Ave

Silver Spring, MD 20993

Phone:

12 GOVERNMENT CONTACTS

Contract Specialist: Sheron Johnson

Email Address: sheron.johnson@fda.hhs.gov

Contracting Officer:

Name: Ian Weiss

Email Address: ian.weiss@fda.hhs.gov

Contracting Officer's Representative:

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

Name: Gary Klaff

Email Address: gary.klaff@fda.hhs.gov

13 HOLIDAYS AND GOVERNMENT CLOSURES

The Contractor is not required to provide on-site services on the following days that are Federal Holidays or on any other day designated as a Federal holiday, Government closure, or shut down for the Washington, D.C. area:

New Year's Day

Martin Luther King Day

President 's Day

Memorial Day

Juneteenth

Independence Day

Labor Day

Columbus Day

Veteran 's Day

Thanksgiving Day

Christmas Day

The Contractor shall not schedule training during federal holidays or Government closure. As necessary, training scheduled during unexpected Government closures may be rescheduled following coordination with the COR. The contractor shall not bill the Government for any training that the Contractor did not perform due to any Government closures.

14 SECURITY AND PRIVACY CONSIDERATIONS

1. Baseline Security Requirements

- a. **Applicability.** The requirements herein apply whether the entire contract or modification (hereafter "contract"), or portion thereof, includes either or both of the following:
 - i. **Access (Physical or Logical) to Government Information:** A Contractor (and/or any subcontractor) will have or will be given the ability to have, routine physical (entry) or logical (electronic) access to government information.

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

- ii. **Operate a Federal System Containing Information:** A Contractor (and/or any subcontractor) will operate a federal system and information technology containing data that supports the FDA mission. In addition to the Federal Acquisition Regulation (FAR) Subpart 2.1 definition of "information technology" (IT), the term as used in this section includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources.
- b. **Safeguarding Information and Information Systems.** All government information and information systems must be protected in accordance with FDA policies and level of risk. At a minimum, the Contractor (and/or any subcontractor) must:
 - i. Protect the:
 - **Confidentiality**, which means preserving authorized restrictions on access and disclosure, based on the security terms found in this contract, including means for protecting personal privacy and proprietary information;
 - **Integrity**, which means guarding against improper information modification or destruction, and ensuring information non-repudiation and authenticity; and
 - **Availability**, which means ensuring timely and reliable access to and use of information.
 - Note to the Requiring Activity Representative:** Complete the following section using the information obtained from the Information Security and Privacy Certification Checklist.
 - ii. Categorize all information owned and/or collected/managed on behalf of FDA and information systems that store, process, and/or transmit FDA information in accordance with FIPS 199 and National Institute of Standards and Technology (NIST) Special Publication (SP) 800-60, Volume II: Appendices to Guide for Mapping Types of Information and Information Systems to Security Categories. Based on information provided by the System/Data Owner, ISSO, privacy

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

representative, or other POC, the impact level for each Security Objective (Confidentiality, Integrity, and Availability) and the Overall Impact Level, which is the highest watermark of the three factors of the information or information system are the following:

- Confidentiality: ☐ Low ☐ Moderate ☒ High
- Integrity: ☐ Low ☐ Moderate ☒ High
- Availability: ☐ Low ☒ Moderate ☐ High
- Overall Impact Level: ☐ Low ☐ Moderate ☒ High

- iii. Based on the agreed-upon level of impact, implement the necessary safeguards to protect all information systems and information collected and/or managed on behalf of FDA regardless of location or purpose.
 - iv. Report any discovered or unanticipated threats or hazards by either the agency or contractor, or if existing safeguards have ceased to function immediately after discovery, within one (1) hour or less, to the government representative(s). This includes notifying the FDA Cybersecurity and Infrastructure Operations Coordination Center (CIOCC) within one (1) hour of discovery/detection in the event of a cybersecurity or privacy incident.
 - v. Adopt and implement all applicable policies, procedures, controls, and standards required by the FDA Information Security Program to ensure the confidentiality, integrity, and availability of government information and government information systems for which the Contractor is responsible under this contract or to which the Contractor may otherwise have access under this contract. Obtain the FDA Information Security Program security requirements, outlined in the FDA Information Security and Privacy Protection (IS2P) policy, by contacting the CO/COR or emailing your ISSO.
- c. **Privacy Act. Comply with the Privacy Act** requirements (when applicable), and tailor FAR and HHSAR clauses as needed.
- d. **Privacy Compliance.** Comply with the E-Government Act of 2002, NIST SP 800-53, and applicable FDA privacy policies and complete all the requirements below:

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

Note to the Requiring Activity Representative: Complete this section using the information obtained from the Information Security and Privacy Certification Checklist. This information may be included after award in the event it is not yet available at the time of acquisition.

- i. Per the Office of Management and Budget (OMB) Circular A-130, Personally Identifiable Information (PII), is "information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual." Examples of PII include, but are not limited to the following: Social Security number, date and place of birth, mother's maiden name, biometric records, etc.
- ii. Based on information provided by the ISSO, System/Data Owner, or other security or privacy representative, it has been determined that this solicitation/contract involves:

☐ No PII ☒ PII

- iii. The Contractor must support the agency with conducting a Privacy Threshold Analysis (PTA) for the information system and/or information handled under this contract to determine whether or not a full Privacy Impact Assessment (PIA) needs to be completed.
 - If the results of the PTA show that a full PIA is needed, the Contractor must support the agency with completing a PIA for the system or information after completion of the PTA and in accordance with HHS and FDA policy and OMB M-03-22, Guidance for Implementing the Privacy Provisions of the E- Government Act of 2002. The PTA/PIA must be completed and approved prior to active use and/or collection or processing of PII and is a prerequisite to agency issuance of an authorization to operate (ATO).
 - The Contractor must support the agency in reviewing the PIA at least every three years throughout the system development lifecycle (SDLC)/information lifecycle, or when determined by the agency that a review is required

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

based on a major change to the system, or when new types of PII are collected that introduces new or increased privacy risks, whichever comes first.

- e. **Controlled Unclassified Information (CUI).** Executive Order 13556 defines CUI as "information that laws, regulations, or Government-wide policies require to have safeguarding or dissemination controls, excluding classified information." The Contractor (and/or any subcontractor) must comply with Executive Order 13556, Controlled Unclassified Information, (implemented at 3 CFR, part 2002) when handling CUI. 32 C.F.R. 2002.4(aa) As implemented the term "handling" refers to "...any use of CUI, including but not limited to marking, safeguarding, transporting, disseminating, re-using, and disposing of the information." 81 Fed. Reg. 63323. The requirements below apply only to nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components. All sensitive information that has been identified as CUI by a regulation or statute, handled by this solicitation/contract, must be:
 - i. Marked appropriately;
 - ii. Disclosed to authorized personnel on a Need-To-Know basis;
 - iii. Protected in accordance with NIST SP 800-53, Security and Privacy Controls for Information Systems and Organizations applicable baseline if handled by a contractor system operated on behalf of the agency, or NIST SP 800-171, Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations if handled by internal Contractor system; and
 - iv. Returned to FDA control, destroyed when no longer needed, or held until otherwise directed. Information and/or data must be disposed of in accordance with NIST SP 800-88, Guidelines for Media Sanitization.
- f. **Protection of Sensitive Information.** For security purposes, information is or may be sensitive because it requires security to protect its confidentiality, integrity, and/or availability. The Contractor (and/or any subcontractor) must protect all government information that is or may be sensitive by securing it with a solution that is validated with current FIPS 140 validation certificate from the NIST CMVP.

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

- g. **Government Furnished Equipment (GFE) for Foreign Travel.** FDA personnel are prohibited from taking GFE when participating in personal, unofficial travel to foreign countries. FDA personnel are strictly prohibited from teleworking using GFE in foreign countries. FDA personnel must also request loaner GFE from the FDA Foreign Travel program for official travel to any foreign country. Please see the FDA IS2P, Appendix T Government Furnished Equipment for Foreign Travel.
- h. **Confidentiality and Nondisclosure of Information.** Any information provided to the contractor (and/or any subcontractor) by FDA or collected by the contractor on behalf of FDA must be used only for the purpose of carrying out the provisions of this contract and must not be disclosed or made known in any manner to any persons except as may be necessary in the performance of the contract. The Contractor assumes responsibility for protection of the confidentiality of Government records and must ensure that all work performed by its employees and subcontractors must be under the supervision of the Contractor. Each Contractor employee or any of its subcontractors to whom any FDA records may be made available or disclosed must be notified in writing by the Contractor that information disclosed to such employee or subcontractor can be used only for that purpose and to the extent authorized herein.

The confidentiality, integrity, and availability of such information must be protected in accordance with HHS and FDA policies. Unauthorized disclosure of information will be subject to the HHS and FDA sanction policies and/or governed by the following laws and regulations:

- i. 18 U.S.C. 641 (Criminal Code: Public Money, Property or Records);
 - ii. 18 U.S.C. 1905 (Criminal Code: Disclosure of Confidential Information);
and
 - iii. 44 U.S.C. Chapter 35, Subchapter I (Paperwork Reduction Act).
-
- i. **Internet Protocol Version 6 (IPv6).** All procurements using Internet Protocol must comply with OMB Memorandum M-05-22, Transition Planning for Internet Protocol Version 6 (IPv6).
 - j. **Information and Communications Technology (ICT).** ICT products and services from prohibited entities/sources must not be used/acquired in compliance with

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

Public Law 115-232, Section 889 Parts A and B, FAR 4.21, FAR 52.204.23, FAR 52.204.24, and FAR 52.204.25. The contractor (and/or any subcontractor) must notify the government if they identify prohibited ICT products and/or services are used during the contract performance.

- k. **Government Websites.** All new and existing public-facing government websites must be securely configured with Hypertext Transfer Protocol Secure (HTTPS) using the most recent version of Transport Layer Security (TLS). In addition, HTTPS must enable HTTP Strict Transport Security (HSTS) to instruct compliant browsers to assume HTTPS at all times to reduce the number of insecure redirects and protect against attacks that attempt to downgrade connections to plain HTTP. For internal-facing websites, HTTPS is not required, but it is highly recommended. Consult the HHS Policy for Internet and Email Security for additional information.
- l. **Contract Documentation.** The Contractor must use provided templates, policies, forms, and other agency documents to comply with contract deliverables as appropriate. Note to the Requiring Activity Representative: See Appendix C for baseline deliverables. Do NOT include in procurement documentation.
- m. **Standard for Encryption.** The Contractor (and/or any subcontractor) must:
 - i. Comply with the HHS Standard for Encryption of Computing Devices and Information to prevent unauthorized access to government information.
 - ii. Encrypt all sensitive federal data and information (i.e., PII, protected health information [PHI], proprietary information, etc.) in transit (i.e., email, network connections, etc.) and at rest (i.e., servers, storage devices, mobile devices, backup media, etc.) with an encryption solution that is validated with current FIPS 140 validation certificates from the NIST CMVP.
 - iii. Secure all devices (i.e.: desktops, laptops, mobile devices, etc.) that store and process government information and ensure devices meet HHS and FDA-specific encryption standard requirements. Maintain a complete and current inventory of all laptop computers, desktop computers, and other mobile devices and portable media that store or process sensitive government information (including PII).
 - iv. Verify that the encryption solutions in use have been validated under the Cryptographic Module Validation Program to confirm compliance with current FIPS 140 validation certificates from the NIST CMVP. The

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

Contractor must provide a written copy of the validation documentation to the COR.

- v. Use the Key Management system on the HHS personal identification verification (PIV) card or establish and use a key recovery mechanism to ensure the ability for authorized personnel to encrypt/decrypt information and recover encryption keys
<http://csrc.nist.gov/publications/>. Encryption keys must be provided to the COR upon request and at the conclusion of the contract.

- n. **Contractor Non-Disclosure Agreement (NDA).** Each Contractor (and/or any subcontractor) employee having access to non-public government information under this contract must complete the FDA non-disclosure agreement (3398 Form)], as applicable. Contractors (and/or subcontractors) must submit a copy of each signed and witnessed NDA to the Contracting Officer (CO) and/or CO Representative (COR) prior to performing any work under this acquisition.

Note to the Requiring Activity Representative: See Appendix D for the FDA Contractor Non-Disclosure Agreement. Do NOT include in procurement documentation.

2. Training Requirements

- a. **Mandatory Training for All Contractor Staff.** All Contractor (and/or any subcontractor) employees assigned to work on this contract must complete the applicable FDA information security awareness, privacy, and records management training (provided upon contract award) before performing any work under this contract. Thereafter, the employees must complete FDA information security awareness, privacy, and records management training at least **annually**, during the life of this contract. All provided training must be compliant with HHS training policies.
- b. **Role-based Training.** All Contractor (and/or any subcontractor) employees with significant security responsibilities (as determined by the program manager) must complete role-based training **annually** commensurate with their role and responsibilities in accordance with HHS and FDA policy.
- c. **Training Records.** The Contractor (and/or any subcontractor) must maintain training records for all its employees working under this contract in accordance with HHS and FDA policy. A copy of the training records must be provided to the

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

CO and/or COR within **30 days** after contract award and **annually** thereafter or upon request.

3. Rules of Behavior

- a. The Contractor (and/or any subcontractor) must ensure that all employees performing on the contract comply with the HHS Information Technology General Rules of Behavior, HHS Rules of Behavior for Privileged Users, and FDA policies and standards.
- b. All Contractor employees performing on the contract must read and adhere to the Rules of Behavior before accessing Agency data or other information, systems, and/or networks that store/process government information, initially at the beginning of the contract and at least annually thereafter, which may be done as part of annual FDA Information Security Awareness Training. If the training is provided by the contractor, the signed ROB must be provided as a separate deliverable to the CO and/or COR per defined timelines above.

4. Incident Response

- a. The Contractor (and/or any subcontractor) must respond to all alerts/Indicators of Compromise (IOCs) provided by HHS Computer Security Incident Response Center (CSIRC)/FDA CIOCC /Incident Response Team teams within 24 hours, whether the response is positive or negative.

FISMA defines an incident as "an occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies. In accordance with OMB M-17-12, Preparing for and Responding to a Breach of *Personally Identifiable Information (PII)*, an incident is "an occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies" and a privacy breach is "the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information or (2) an authorized user accesses or potentially accesses personally

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

identifiable information for an other than authorized purpose." For additional information on the HHS breach response process, please see the FDA IS2P Appendix F: Incident Response and the *HHS Policy and Plan for Preparing for and Responding to a Breach of Personally Identifiable Information (PII)*."

- b. In the event of a suspected or confirmed incident or breach, the Contractor (and/or any subcontractor) must:
 - i. Protect all sensitive information, including any PII created, stored, or transmitted in the performance of this contract, with encryption solution that is validated with current FIPS 140 validation certificates from the NIST CMVP.
 - ii. NOT notify affected individuals unless so instructed by the Contracting Officer or designated representative. If so, instructed by the Contracting Officer or representative, the Contractor must send FDA approved notifications to affected individuals as directed by FDA's SOP.
 - iii. Report all suspected and confirmed information security and privacy incidents and breaches to the FDA CIOCC, COR, CO, FDA SOP (or his or her designee), and other stakeholders, including breaches involving PII, in any medium or form, including paper, oral, or electronic, as soon as possible and without unreasonable delay, no later than one (1) hour, and consistent with the applicable FDA and HHS policy and procedures, NIST standards and guidelines, as well as US-CERT notification guidelines. The types of information required in an incident report must include at a minimum: company and point of contact information, contact information, impact classifications/threat vector, and the type of information compromised. In addition, the Contractor must:
 - Cooperate and exchange any information, as determined by the Agency, necessary to effectively manage or mitigate a suspected or confirmed breach;
 - Not include any sensitive information in the subject or body of any reporting e-mail; and

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

- Encrypt sensitive information in attachments to email, media, etc.
- iv. Comply with OMB M-17-12, Preparing for and Responding to a Breach of Personally Identifiable Information, and HHS and FDA breach response policies when handling PII breaches.
- v. Provide full access and cooperate on all activities as determined by the Government to ensure an effective incident response, including providing all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents. This may involve disconnecting the system processing, storing, or transmitting the sensitive information from the Internet or other networks or applying additional security controls. This may also involve physical access to contractor facilities during a breach/incident investigation on demand.

5. Position Sensitivity Designations

All Contractor (and/or any subcontractor) employees must obtain a background investigation commensurate with their position sensitivity designation that complies with Parts 1400 and 731 of Title 5, Code of Federal Regulations (CFR). The following position sensitivity designation levels apply to this solicitation/contract (e.g. tier 1, 2, or 4): Tier 2.

Note to the Requiring Activity Representative: *The Requiring Activity Representative, in conjunction with Personnel Security, must use the OPM Position Sensitivity Designation automated tool (<https://www.opm.gov/investigations/>) to determine the sensitivity designation for background investigations. After making those determinations, include all applicable position sensitivity designations.*

6. Homeland Security Presidential Directive (HSPD)-12

The Contractor (and/or any subcontractor) and its employees must comply with Homeland Security Presidential Directive (HSPD)-12, *Policy for a Common Identification Standard for Federal Employees and Contractors*; OMB M-05-24; OMB M-19-17; FIPS 201, *Personal Identity Verification (PIV) of Federal Employees and Contractors*; HHS HSPD-12 policy; and *Executive Order 13467, Part 1 §1.2*.

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

Note to the Requiring Activity Representative: For additional information, see HSPD-12 policy at: <https://www.dhs.gov/homeland-security-presidential-directive-12>

7. Roster

The Contractor (and/or any subcontractor) must submit a roster by name, position, e-mail address, phone number and responsibility, of all staff working under this acquisition where the Contractor will develop, have the ability to access, or host and/or maintain a government information system(s). The roster must be submitted to the COR and/or CO per the COR or CO's direction. Any revisions to the roster as a result of staffing changes must be submitted within a timeline as directed by the COR and/or CO. The COR will notify the Contractor of the appropriate level of investigation required for each staff member.

If the employee is filling a new position, the Contractor must provide a position description and the Government will determine the appropriate suitability level.

8. Contract Initiation and Expiration

- a. **General Security Requirements.** The Contractor (and/or any subcontractor) must comply with information security and privacy requirements, Enterprise Performance Life Cycle (EPLC) processes, HHS Enterprise Architecture requirements to ensure information is appropriately protected from initiation to expiration of the contract. All information systems development or enhancement tasks supported by the contractor must follow the FDA EPLC framework and methodology in accordance with the FDA EPLC Project documentation, located here: <http://sharepoint.fda.gov/orgs/DelMgmtSupport/IntakeProc/EPLCv2/SitePages/v2/EPLCHome.aspx> and in accordance with the [HHS Contract Closeout Guide \(2012\)](#).
- b. **System Documentation.** Contractors (and/or any subcontractors) must follow and adhere to HHS System Development Life Cycle requirements, at a minimum, for system development and provide system documentation at designated intervals (specifically, at the expiration of the contract) within the EPLC that require artifact review and approval.
- c. **Sanitization of Government Files and Information.** As part of contract closeout and at expiration of the contract, the Contractor (and/or any subcontractor) must provide all required documentation in accordance with SMGs published by

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

FDA's Office of Acquisitions and Grant Services (OAGS) to the CO and/or COR to certify that, at the government's direction, all electronic and paper records are appropriately disposed of and all devices and media are sanitized in accordance with NIST SP 800-88, Guidelines for Media Sanitization.

- d. **Notification.** The Contractor (and/or any subcontractor) must notify the CO and/or COR and system ISSO as soon as it is known that a contract employee will stop working under this contract.
- e. **Contractor Responsibilities upon Physical Completion of the Contract.** The contractor (and/or any subcontractors) must return all government information and IT resources (i.e., government information in non-government-owned systems, media, and backup systems) acquired during the term of this contract to the CO and/or COR. Additionally, the Contractor must provide a certification that all government information has been properly sanitized and purged from Contractor-owned systems, including backup systems and media used during contract performance, in accordance with HHS and FDA policies.
- f. The Contractor (and/or any subcontractor) must perform and document the actions identified in the FDA eDepart system
<http://inside.fda.gov:9003/EmployeeResources/NewEmployee/eDepartDepartureSystem/default.htm> as soon as it is known that a contract an employee will terminate work under this contract. The Contractor (and/or any subcontractor) shall coordinate with the COR via email, copying the Contract Specialist, to ensure that the appropriate person performs and documents the actions identified in the FDA eDepart system. All documentation must be available to the CO and/or COR upon request.

9. Records Management and Retention

- a. The Contractor (and/or any subcontractor) must maintain all information in accordance with Executive Order 13556 -- Controlled Unclassified Information, National Archives and Records Administration (NARA) records retention policies and schedules and HHS Policy for Records Management and HHS and FDA policies and must not dispose of any records unless authorized by HHSFDA.
- b. In the event that a contractor (and/or any subcontractor) accidentally disposes of or destroys a record without proper authorization, he/she must document and report the incident in accordance with HHS and FDA policies.

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

10. High Value Asset (HVA)

If a system is identified as HVA, the contractor must comply with the FDA IS2P Appendix AB: High Value Asset (HVA) Program, the HHS Policy for the High Value Asset (HVA) Program, and the DHS HVA Control Overlay in addition to the above requirements.

15 PROPOSAL INSTRUCTIONS

Please see the preceding cover letter for instructions.

16 CONTRACT CLAUSES

This Order is subject to the terms and conditions provided in the Offeror's BPA as well as the Contractor's GSA FSS Contract and those outlined in this BPA Order. In the event of a conflict between documents, the following order of precedence shall apply:

1. Contractor's FSS Contract
2. Offeror's BPA
3. BPA Order

Federal Acquisition Regulation (FAR) Clauses Incorporated by Reference:

- FAR 52.204-25 Prohibition on Contracting for Certain Telecommunications and Video Surveillance Services or Equipment (Aug 2020)
- FAR 52.222-26 Equal Opportunity (Sep 2016)

Federal Acquisition Regulation (FAR) Clauses Incorporated in Full Text:

16.1 FAR 52.217-8 OPTION TO EXTEND SERVICES (Nov 1999)

The Government may require continued performance of any services within the limits and at the rates specified in the contract. These rates may be adjusted only as a result of revisions to prevailing labor rates provided by the Secretary of Labor. The option provision may be exercised more than once, but the total extension of performance hereunder shall not exceed 6 months. The Contracting Officer may exercise the option by written notice to the Contractor any time before the contract expires.

Health and Human Services Acquisition Regulation (HHSAR) Clauses Incorporated in Full Text

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

**16.2 HHSAR 352.239-74 ELECTRONIC INFORMATION AND TECHNOLOGY ACCESSIBILITY
(DEC 2015)**

- (a) Pursuant to Section 508 of the Rehabilitation Act of 1973 (29 U.S.C. 794d), as amended by the Workforce Investment Act of 1998, all electronic and information technology (EIT) supplies and services developed, acquired, or maintained under this contract or order must comply with the “Architectural and Transportation Barriers Compliance Board Electronic and Information Technology (EIT) Accessibility Standards” set forth by the Architectural and Transportation Barriers Compliance Board (also referred to as the “Access Board”) in 36 CFR part 1194. Information about Section 508 is available at <http://www.hhs.gov/web/508>. The complete text of Section 508 Final Provisions can be accessed at <http://www.access-board.gov/guidelines-and-standards/communications-and-it/about-the-section-508-standards>.
- (b) The Section 508 accessibility standards applicable to this contract or order are identified in the Statement of Work or Specification or Performance Work Statement. The contractor must provide any necessary updates to the submitted HHS Product Assessment Template(s) at the end of each contract or order exceeding the simplified acquisition threshold (see [FAR 2.101](#)) when the contract or order duration is one year or less. If it is determined by the Government that EIT supplies and services provided by the Contractor do not conform to the described accessibility standards in the contract, remediation of the supplies or services to the level of conformance specified in the contract will be the responsibility of the Contractor at its own expense.
- (c) The Section 508 accessibility standards applicable to this contract are:
- Must meet WCAG 2.0 A and AA
 - E101.2 Equivalent Facilitation (Appendix A, Application and Scoping Requirements)
 - E203 Access to Functionality (Appendix A, Application and Scoping Requirements)
 - E204 Functional Performance Criteria (Appendix A, Application and Scoping Requirements)
 - E205 Electronic Content (Appendix A, Application and Scoping Requirements)
 - 302 Functional Performance Criteria (Appendix C, Functional Performance Criteria and Technical Requirements)
 - Electronic content must be accessible to HHS acceptance criteria. Checklist for various formats are available at <http://508.hhs.gov/>, or from the Section 508 Coordinator listed at <https://www.hhs.gov/web/section-508/additional-resources/section-508-contacts/index.html>. Materials that are final items for delivery should be accompanied by the appropriate checklist, except upon approval of the Contracting

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

Officer or Representative.

- (d) In the event of a modification(s) to this contract or order, which adds new EIT supplies or services or revises the type of, or specifications for, supplies or services, the Contracting Officer may require that the contractor submit a completed HHS Section 508 Product Assessment Template and any other additional information necessary to assist the Government in determining that the EIT supplies or services conform to Section 508 accessibility standards. Instructions for documenting accessibility via the HHS Section 508 Product Assessment Template may be found under Section 508 policy on the HHS website: (<http://www.hhs.gov/web/508>). If it is determined by the Government that EIT supplies and services provided by the Contractor do not conform to the described accessibility standards in the contract, remediation of the supplies or services to the level of conformance specified in the contract will be the responsibility of the Contractor at its own expense.
- (e) If this is an Indefinite Delivery contract, a Blanket Purchase Agreement or a Basic Ordering Agreement, the task/delivery order requests that include EIT supplies or services will define the specifications and accessibility standards for the order. In those cases, the Contractor may be required to provide a completed HHS Section 508 Product Assessment Template and any other additional information necessary to assist the Government in determining that the EIT supplies or services conform to Section 508 accessibility standards. Instructions for documenting accessibility via the HHS Section 508 Product Assessment Template may be found at <http://www.hhs.gov/web/508>. If it is determined by the Government that EIT supplies and services provided by the Contractor do not conform to the described accessibility standards in the provided documentation, remediation of the supplies or services to the level of conformance specified in the contract will be the responsibility of the Contractor at its own expense.

(End of clause)

16.3 52.204-27 PROHIBITION ON A BYTEDANCE COVERED APPLICATION.

As prescribed in [4.2203\(c\)](#), insert the following clause:

PROHIBITION ON A BYTEDANCE COVERED APPLICATION (JUN 2023)

(a) *Definitions.* As used in this clause—

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

Covered application means the social networking service TikTok or any successor application or service developed or provided by ByteDance Limited or an entity owned by ByteDance Limited.

Information technology, as defined in 40 U.S.C. 11101(6)—

(1) Means any equipment or interconnected system or subsystem of equipment, used in the automatic acquisition, storage, analysis, evaluation, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information by the executive agency, if the equipment is used by the executive agency directly or is used by a contractor under a contract with the executive agency that requires the use—

(i) Of that equipment; or

(ii) Of that equipment to a significant extent in the performance of a service or the furnishing of a product;

(2) Includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources; but

(3) Does not include any equipment acquired by a Federal contractor incidental to a Federal contract.

(b) *Prohibition.* Section 102 of Division R of the Consolidated Appropriations Act, 2023 (Pub. L. 117-328), the No TikTok on Government Devices Act, and its implementing guidance under Office of Management and Budget (OMB) Memorandum M-23-13, dated February 27, 2023, “No TikTok on Government Devices” Implementation Guidance, collectively prohibit the presence or use of a covered application on executive agency information technology, including certain equipment used by Federal contractors. The Contractor is prohibited from having or using a covered application on any information technology owned or managed by the Government, or on any information technology used or provided by the Contractor under this contract, including equipment provided by the Contractor’s employees; however, this prohibition does not apply if the Contracting Officer provides written notification to the Contractor that an exception has been granted in accordance with OMB Memorandum M-23-13.

(c) *Subcontracts.* The Contractor shall insert the substance of this clause, including this paragraph (c), in all subcontracts, including subcontracts for the acquisition of commercial products or commercial services.

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

(End of clause)

1. The following clauses are incorporated into the contract:
 - a. **352.232-71 Electronic Submission of Payment Requests (FEB 2022)**

(a) Definitions. As used in this clause—

Payment request means a bill, voucher, invoice, or request for contract financing payment with associated supporting documentation. The payment request must comply with the requirements identified in FAR 32.905(b), “Content of Invoices” and the applicable Payment clause included in this contract.

(b) Except as provided in paragraph (c) of this clause, the Contractor shall submit payment requests electronically using the Department of Treasury Invoice Processing Platform (IPP) or successor system. Information regarding IPP, including IPP Customer Support contact information, is available at www.ipp.gov or any successor site.

(c) The Contractor may submit payment requests using other than IPP only when the Contracting Officer authorizes alternate procedures in writing in accordance with HHS procedures.

(d) If alternate payment procedures are authorized, the Contractor shall include a copy of the Contracting Officer's written authorization with each payment request.

(End of clause)

IPP Invoicing Instructions

(a) All Invoice submissions for goods and or services must be made electronically through the

U.S. Department of Treasury’s Invoice Processing Platform System (IPP).
<http://www.ipp.gov/vendors/index.htm>

(b) Invoice Submission for Payment means any request for contract financing payment or invoice payment by the Contractor. To constitute a proper invoice, the payment request must comply with the requirements identified in in FAR 32.905(b), “Content of Invoices” and the applicable Payment clause included in this contract, or the clause 52.212-4 Contract Terms and Conditions – Commercial Items included in commercial items contracts. The IPP website address is: <https://www.ipp.gov>.

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

(c) The Agency will enroll the Contractors new to IPP. The Contractor must follow the IPP registration email instructions for enrollment to register the Collector Account for submitting invoice requests for payment. The Contractor Government Business Point of Contact (as listed in SAM) will receive Registration email from the Federal Reserve Bank of St. Louis (FRBSTL) within 3 – 5 business days of the contract award for new contracts or date of modification for existing contracts.

(1) Registration emails are sent via email from ipp.noreply@mail.eroc.twai.gov. Contractor assistance with enrollment can be obtained by contacting the IPP Production Helpdesk via email to IPPCustomerSupport@fiscal.treasury.gov or phone (866) 973-3131.

(2) The Contractor POC will receive two emails from IPP Customer Support, the first email contains the initial administrative IPP User ID. The second email, sent within 24 hours of receipt of the first email, contains a temporary password. You must log in with the temporary password within 30 days.

(3) If your company is already registered to use IPP, you will not be required to re-register.

(4) If the Contractor is unable to comply with the requirement to use IPP for submitting invoices for payment as authorized by HHSAR 332.7002, a written request must be submitted to the Contracting Officer to explain the circumstances that require the authorization of alternate payment procedures.

(d) Invoices that include time and materials or labor hours Line Items must include supporting documentation to

(1) substantiate the number of labor hours invoiced for each labor category, and

(2) substantiate material costs incurred (when applicable).

(e) Invoices that include cost-reimbursement Line Items must be submitted in a format showing expenditures for that month, as well as contract cumulative amounts. (1) At a minimum the following cost information shall be included, in addition to supporting documentation to substantiate costs incurred. - Direct Labor - include all persons, listing the person's name, title, number of hours worked, hourly rate, the total cost per person and a total amount for this category;

- Indirect Costs (i.e., Fringe Benefits, Overhead, General and Administrative, Other Indirect)- show rate, base and total amount; - Consultants (if applicable) - include the name, number of days or hours worked, daily or hourly rate, and a total amount per consultant;

**STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING**

- Travel - include for each airplane or train trip taken the name of the traveler, date of travel, destination, the transportation costs including ground transportation shown separately and the per diem costs. Other travel costs shall also be listed.

- Subcontractors (if applicable) - include, for each subcontractor, the same data as required for the prime Contractor.

- Other Direct Costs - include a listing of all other direct charges to the contract, i.e., office supplies, telephone, duplication, postage; and

- Fee – amount as allowable in accordance with the Schedule and FAR 52.216-8 if applicable.

(f) Contractor is required to attach an invoice log addendum to each invoice which shall include, at a minimum, the following information for contract administration and reconciliation purposes:

(1) list of all invoices submitted to date under the subject award, including the following: -
invoice number, amount, & date submitted

- corresponding payment amount & date received

- total amount of all payments received to date under the subject contract or order

- and, for definitized contracts or orders only, total estimated amounts yet to be invoiced for the current, active period of performance.

(g) Payment of invoices will be made based upon acceptance by the Government of the entire task or the tangible product deliverable(s) invoiced. Payments shall be based on the Government certifying that satisfactory services were provided, and the Contractor has certified that labor charges are accurate.

(h) If the services are rejected for failure to conform to the technical requirements of the task order, or any other contractually legitimate reason, the Contractor shall not be paid, or shall be paid an amount negotiated by the CO.

(i) Payment to the Contractor will not be made for temporary work stoppage due to circumstances beyond the control of U.S. Food and Drug Administration such as acts of God, inclement weather, power outages, and results thereof, or temporary closings of facilities at which Contractor personnel are performing. This may, however, be justification for excusable delays.

STATEMENT OF WORK
CENTER FOR DEVICES AND RADIOLOGICAL HEALTH (CDRH)
SBOM VALIDATION AND REPORTING

(j) The Contractor agrees that the submission of an invoice to the Government for payment is a certification that the services for which the Government is being billed, have been delivered in accordance with the hours shown on the invoices, and the services are of the quality required for timely and successful completion of the effort.

(k) Questions regarding invoice payments that cannot be resolved by the IPP Helpdesk should be directed to the FDA Employee Resource and Information Center (ERIC)

Refer to the Call-in menu options and follow the phone prompts to dial the option that corresponds to the service that's needed. All ERIC Service Now Tickets will either be responded to or resolved within 48 hours (2 business days) of being received. When emailing, please be sure to include the contract number, invoice number and date of invoice, as well as your name, phone number, and a detailed description of the issue.

Helpdesk at 301-827- ERIC (3742) or toll-free 866-807-ERIC (3742); or, by email at ERIC@fda.hhs.gov. Refer to the Call-in menu options and follow the phone prompts to dial the option that corresponds to the service that's needed. All ERIC ServiceNow Tickets will either be responded to or resolved within 48 hours (2 business days) of being received. When emailing, please be sure to include the contract number, invoice number and date of invoice, as well as your name, phone number, and a detailed description of the issue.
(END OF CLAUSE)